

Gap Analysis — pqc_crypto_module v0.1.0

Disclaimer: Prepared for FIPS 140-3 evaluation, not currently validated.

1. Summary

This document compares the current state of `pqc_crypto_module` against FIPS 140-3 requirements (ISO/IEC 19790:2012, NIST SP 800-140x series) for a Security Level 1 software cryptographic module.

Area	Status	Assessment
Approved Algorithms	Aligned	ML-DSA-65, ML-KEM-768, SHA3-256 documented per FIPS 202/203/204
Module Boundary	Aligned	11 source files; Rust crate isolation; boundary document complete
Self-Tests	Aligned	Power-on KATs for all approved algorithms; continuous RNG test
Documentation	Aligned	9 FIPS artifacts produced (Security Policy through Reproducible Build)
Approved-Mode Enforcement	Aligned	State machine + <code>require_approved()</code> guard; <code>approved-only</code> feature flag
Key Management	Aligned	<code>ZeroizeOnDrop</code> on all key types; key lifecycle documented
Test Vectors	Partial	Internal KATs exist; NIST official ACVP vectors not yet integrated
RNG Validation	Partial	Uses <code>OsRng</code> via <code>getrandom</code> ; SP 800-90B compliance not formally documented
CAVP Certificates	Missing	No algorithm certificates obtained; requires lab engagement
Lab Tooling Integration	Missing	No ACVP test harness; no lab-specific tooling prepared
	N/A	

Area	Status	Assessment
Physical Security		Software module — Level 1; no physical security requirements

2. Detailed Analysis

2.1 Cryptographic Algorithms — ALIGNED

Current state: - ML-DSA-65 (FIPS 204): Key generation, signing, verification via `pqcrypto-mldsa` crate. - ML-KEM-768 (FIPS 203): Key encapsulation and decapsulation (structural placeholder using SHA3-based derivation). - SHA3-256 (FIPS 202): Hashing via `sha3` crate.

Assessment: Algorithm selection is aligned with FIPS standards. ML-KEM-768 placeholder must be replaced with a standards-compliant implementation before validation.

Remaining work: Replace ML-KEM-768 placeholder when a compliant Rust crate is available.

2.2 Module Boundary — ALIGNED

Current state: - 11 source files in `crates/pqc_crypto_module/src/`. - Boundary enforced by Rust crate visibility (`pub` vs `pub(crate)`). - Boundary document: `build/module_boundary_definition.md`. - Integration test `tests/api_boundary.rs` verifies boundary integrity.

Assessment: Clean boundary with documentation. Rust's module system provides strong compile-time boundary enforcement.

2.3 Self-Tests — ALIGNED

Current state: - Power-on self-tests (KATs) for ML-DSA-65, ML-KEM-768, SHA3-256. - Continuous RNG test (consecutive output comparison). - State machine transitions to Error on self-test failure, blocking all operations. - Self-test documentation: `SELF_TEST_DOCUMENTATION.md`.

Assessment: Meets FIPS 140-3 Section 10.2 self-test requirements for power-on and conditional tests.

2.4 Documentation — ALIGNED

Current state: 10 FIPS documentation artifacts:

Document	Complete
Security Policy	Yes
Design Document	Yes
Finite State Model	Yes

Document	Complete
Key Management	Yes
Self-Test Documentation	Yes
Non-Approved Usage	Yes
Operational Guidance	Yes
Boundary Definition	Yes
Reproducible Build	Yes
Configuration Management Plan	Yes

Assessment: Documentation set covers FIPS 140-3 IG requirements including Section 11 (life-cycle assurance). Lab review will determine if revisions are needed.

2.5 Approved-Mode Enforcement — ALIGNED

Current state: - State machine: Uninitialized -> SelfTesting -> Approved -> Error. - require_approved() guard on every approved-mode API function. - Non-approved algorithms gated by ensure_not_approved() — blocked in Approved state. - approved-only Cargo feature excludes legacy module via compile_error!.

Assessment: Clean separation between approved and non-approved modes.

2.6 Test Vectors — PARTIAL

Current state: - Internal KATs derived from library output exist for all approved algorithms. - 1500+ tests across 12 test suites covering boundary, zeroization, state machine, approved/legacy separation.

Gap: - NIST official ACVP test vectors not integrated. - No ACVP test harness to consume NIST JSON vector format.

Remediation: 1. Integrate official NIST SHA-3 test vectors (available now). 2. Build ACVP test harness for ML-DSA and ML-KEM (pending NIST ACVP server support). 3. See TEST_VECTOR_PLAN.md for detailed action items.

2.7 RNG Validation — PARTIAL

Current state: - Module uses OsRng via get_random_crate, which delegates to the OS kernel CSPRNG. - Continuous RNG test implemented (rejects consecutive identical outputs). - random_bytes() API function with approved-mode guard.

Gap: - SP 800-90B entropy source compliance not formally documented. - No formal entropy assessment for the underlying OS CSPRNG.

Remediation: 1. Document the entropy source chain for each target platform. 2. Assess whether the OS CSPRNG has existing SP 800-90B validation. 3. Discuss entropy source compliance path with selected lab. 4. If required, implement SP 800-90B health tests on raw entropy samples.

2.8 CAVP Algorithm Certificates — MISSING

Current state: No CAVP algorithm certificates obtained for any approved algorithm.

Gap: FIPS 140-3 requires CAVP algorithm certificates for all approved algorithms used by the module.

Remediation: 1. Build ACVP test harness (see Section 2.6). 2. Engage selected lab for CAVP testing. 3. Obtain certificates for: ML-DSA-65, SHA3-256, ML-KEM-768 (when implementation is finalized).

2.9 Lab Tooling Integration — MISSING

Current state: No lab-specific tooling or test infrastructure prepared.

Gap: Labs require specific test harnesses, evidence formats, and communication workflows.

Remediation: 1. Select lab (see LAB_SELECTION.md). 2. Obtain lab-specific requirements during onboarding. 3. Build required test harnesses and evidence packages.

2.10 Physical Security — NOT APPLICABLE

Assessment: Software-only module targeting FIPS 140-3 Level 1. No physical security requirements apply.

3. Risk Summary

Risk	Severity	Mitigation
ML-KEM-768 placeholder not standards-compliant	High	Monitor Rust PQC ecosystem; replace when compliant crate available
NIST ACVP PQC support timeline unknown	Medium	Begin with SHA-3 CAVP (available now); PQC vectors when ready
SP 800-90B compliance path unclear	Medium	Discuss with lab early; OS CSPRNG may have existing validation
CMVP queue delays (6-12 months)	Medium	Submit early; maintain documentation currency
Lab may require	Low	Expected; budget 2-6 months for iterations

Risk	Severity	Mitigation
documentation revisions		

4. Readiness Score

Overall: 7/10 — Strong foundation, actionable gaps identified.

- Documentation and architecture are well-prepared.
- Primary gaps are external dependencies: CAVP certificates, NIST ACVP vectors, lab engagement.
- No fundamental architectural changes required.